

MCP Threat Model

Owner: William
Reviewer: Charoes
Contributors:
Date Generated: Fri Dec 26 2025

Executive Summary

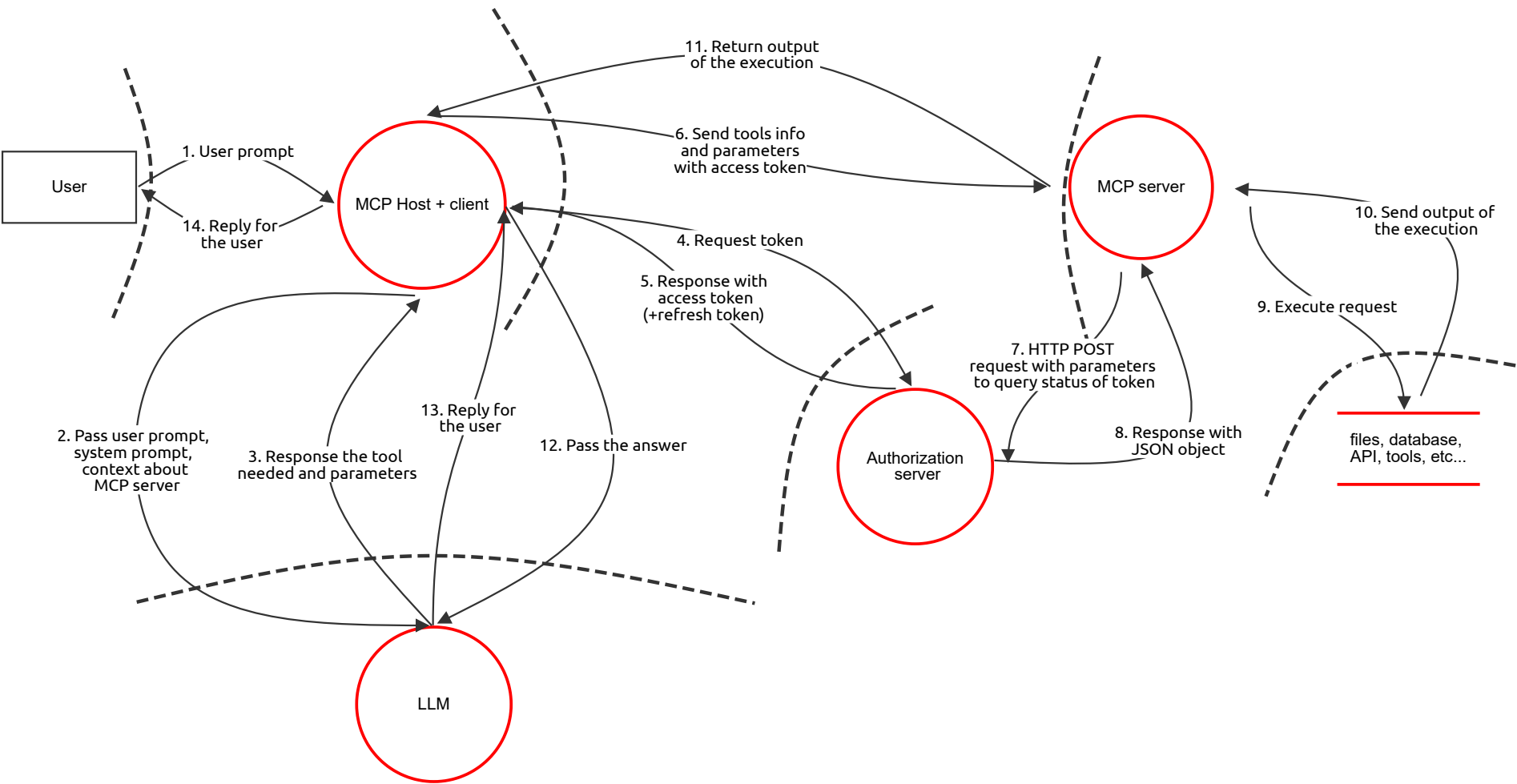
High level system description

MCP (Model Context Protocol) is an open-source standard for connecting AI applications to external systems.

Summary

Total Threats	57
Total Mitigated	0
Total Open	57
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0
Open / TBD Severity	57

MCP Threat Model



MCP Threat Model

MCP Host + client (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	Client side - Impersonation	Spoofing	TBD	Open		Attackers pretend to be valid clients to access the system without authorization.	Defences include providing enforcement of behavioral workflow and anti-automation
2	Client side - Insecure Communication	Tampering	TBD	Open		Data exchanged between client and server can be intercepted or altered.	Defence includes providing anti-automation
3	Client side - Operational Errors	Denial of service	TBD	Open		Mismatch between client and server schemas causes system malfunctions.	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
4	Client side - Unpredictable Behavior	Denial of service	TBD	Open		Model instability results in irregular or disruptive requests.	Provide remediation for this threat or a reason if status is N/A
5	Host side - AI Model Vulnerabilities	Denial of service	TBD	Open		Faulty outputs or exploited weaknesses disrupt MCP function.	Provide remediation for this threat or a reason if status is N/A
6	Host side - Host System Compromise	Elevation of privilege	TBD	Open		Host machine compromise leads to unauthorized privilege escalation.	Provide remediation for this threat or a reason if status is N/A
84	MCP Configuration Poisoning	Tampering	TBD	Open		Malicious .mcp/config.json files hidden in repositories automatically load when developers open projects in their IDEs, connecting to attacker-controlled servers without requiring any user interaction beyond opening the project.	Provide remediation for this threat or a reason if status is N/A
85	Tool Name Spoofing	Tampering	TBD	Open		Attackers create malicious tools with names resembling legitimate ones using homoglyphs, Unicode tricks, or typosquatting, deceiving users into installing them.	Provide remediation for this threat or a reason if status is N/A
86	Configuration File Exposure	Information disclosure	TBD	Open		Configuration files containing API keys, server URLs, and authentication tokens are exposed through web servers, public repositories, or world-readable file locations.	Provide remediation for this threat or a reason if status is N/A
105	Session Management Flaws	Information disclosure	TBD	Open		MCP protocol lacks defined session management, including lifecycle controls, timeouts, and revocation capabilities.	Provide remediation for this threat or a reason if status is N/A

LLM (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
21	LLM01: Prompt Injection	Tampering	TBD	Open		Malicious prompts manipulate model behavior or leak data.	Provide remediation for this threat or a reason if status is N/A
75	LLM02: Insecure Output Handling	Information disclosure	TBD	Open		Poor validation of model responses exposes sensitive data or executes unintended actions.	Provide remediation for this threat or a reason if status is N/A
76	LLM03: Training Data Poisoning	Tampering	TBD	Open		Tampered training data reduces model accuracy or integrity.	Provide remediation for this threat or a reason if status is N/A
77	LLM04: Model Denial of Service	Denial of service	TBD	Open		Resource-intensive prompts disrupt normal model operation.	Provide remediation for this threat or a reason if status is N/A
78	LLM05: Supply Chain Vulnerabilities	Tampering	TBD	Open		Compromised datasets or dependencies reduce trustworthiness.	Provide remediation for this threat or a reason if status is N/A

Number	Title	Type	Severity	Status	Score	Description	Mitigations
79	LLM06: Sensitive Information Disclosure	Information disclosure	TBD	Open		Model outputs unintentionally reveal confidential information.	Provide remediation for this threat or a reason if status is N/A
80	LLM07: Insecure Plugin Design	Elevation of privilege	TBD	Open		Poor plugin controls enable unauthorized system actions.	Provide remediation for this threat or a reason if status is N/A
81	LLM08: Excessive Agency	Elevation of privilege	TBD	Open		Overly autonomous models make unsafe or unauthorized decisions	Provide remediation for this threat or a reason if status is N/A
82	LLM09: Overreliance	Tampering	TBD	Open		Blind trust in model outputs leads to security or decision errors.	Provide remediation for this threat or a reason if status is N/A
83	LLM10: Model Theft	Information disclosure	TBD	Open		Unauthorized access to model parameters or structure exposes proprietary assets.	Provide remediation for this threat or a reason if status is N/A
106	MCP Preference Manipulation Attack (MPMA)	Tampering	TBD	Open		Biased tool responses gradually alters LLM decision-making patterns	Provide remediation for this threat or a reason if status is N/A
107	Advanced Tool Poisoning (ATPA)	Tampering	TBD	Open		Exploit adversarial examples and context manipulation to alter how LLMs understand and use tools	Provide remediation for this threat or a reason if status is N/A
108	Context Bleeding	Information disclosure	TBD	Open		Inadequate session isolation in shared LLM deployments allows context from one user's conversation to leak into others	Provide remediation for this threat or a reason if status is N/A

1. User prompt (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

2. Pass user prompt, system prompt, context about MCP server (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

3. Response the tool needed and parameters (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

6. Send tools info and parameters with access token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

5. Response with access token (+refresh token) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

9. Execute request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

10. Send output of the execution (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

11. Return output of the execution (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

12. Pass the answer (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

13. Reply for the user (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

14. Reply for the user (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

8. Response with JSON object (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

7. HTTP POST request with parameters to query status of token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

4. Request token (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

MCP server (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Compromise and Unauthorized Access	Spoofing	TBD	Open		Misconfigurations or insecure setups allow intruder access.	Defences include providing enforcement of behavioral workflow and anti-automation

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Exploitation of Functions	Tampering	TBD	Open		Attackers misuse tools to perform unintended or harmful operations	Defence includes providing anti-automation
9	Denial of Service	Denial of service	TBD	Open		Overloading the server with excessive or looping requests disrupts service	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
10	Vulnerable Communication	Tampering	TBD	Open		Data transmitted between entities may be intercepted or modified.	Provide remediation for this threat or a reason if status is N/A
11	Client Interference	Denial of service	TBD	Open		Lack of isolation allows one client’s activity to affect others.	Provide remediation for this threat or a reason if status is N/A
12	Data Leakage and Compliance Violations	Information disclosure	TBD	Open		Sensitive data is exfiltrated or mishandled, breaching regulations.	Provide remediation for this threat or a reason if status is N/A
13	Insufficient Auditability	Repudiation	TBD	Open		Weak or missing logs make security incident investigation difficult.	Provide remediation for this threat or a reason if status is N/A
14	Server Spoofing	Spoofing	TBD	Open		Fake servers imitate legitimate ones to deceive users or systems.	Provide remediation for this threat or a reason if status is N/A
87	Unauthenticated access	Information disclosure	TBD	Open		MCP endpoints often lack authentication, creating a security gap that enables multiple attack vectors.	Provide remediation for this threat or a reason if status is N/A
88	Command Injection	Elevation of privilege	TBD	Open		Unsanitized user input flowing into system commands like semicolons, pipes, or backticks.	Provide remediation for this threat or a reason if status is N/A
90	Remote Code Execution	Elevation of privilege	TBD	Open		Complete system control including command injection, unsafe deserialization, or memory vulnerabilities	Provide remediation for this threat or a reason if status is N/A
91	Confused Deputy	Denial of service	TBD	Open		MCP servers fail to verify which credentials belong to which requester	Provide remediation for this threat or a reason if status is N/A
92	Localhost Bypass (NeighborJack)	Information disclosure	TBD	Open		Attackers bypass localhost restrictions to gain unauthorized access.	Provide remediation for this threat or a reason if status is N/A
93	Rug Pull Attack	Spoofing	TBD	Open		Malicious updates or changes compromise previously trusted servers.	Provide remediation for this threat or a reason if status is N/A
94	Full Schema Poisoning (FSP)	Tampering	TBD	Open		Attackers inject malicious data into schema definitions.	Provide remediation for this threat or a reason if status is N/A
95	Cross-Repository Data Theft	Information disclosure	TBD	Open		Unauthorized access to data across different repositories.	Provide remediation for this threat or a reason if status is N/A
96	Cross-Tenant Data Exposure	Information disclosure	TBD	Open		Inadequate isolation allows data leakage across tenants through shared caches, logs, or resource pools.	Provide remediation for this threat or a reason if status is N/A
103	Tool Shadowing	Spoofing	TBD	Open		Malicious tools masquerade as legitimate ones to deceive users or systems.	Provide remediation for this threat or a reason if status is N/A
109	Token passthrough / Token replay attack	Tampering	TBD	Open		Servers forward client authentication tokens to backend services without validating them, checking expiration, or verifying scope	Provide remediation for this threat or a reason if status is N/A

User (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
--------	-------	------	----------	--------	-------	-------------	-------------

files, database, API, tools, etc... (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	Data - Insufficient Access Control	Information disclosure	TBD	Open		Weak data protection permits unauthorized access.	

Number	Title	Type	Severity	Status	Score	Description	Mitigations
16	Data Integrity Issues	Tampering	TBD	Open		Altered or inconsistent data leads to incorrect outcomes.	Defence includes providing anti-automation
17	Data Exfiltration	Information disclosure	TBD	Open		Confidential data is extracted without authorization.	Mitigation or prevention such as providing backoff, resource management and avoiding forced deadlock
18	Tool - Functional Misuse	Tampering	TBD	Open		Tools are used beyond their intended security scope.	Provide remediation for this threat or a reason if status is N/A
19	Tool - Resource Exhaustion	Denial of service	TBD	Open		Excessive tool use depletes available resources.	Provide remediation for this threat or a reason if status is N/A
20	Tool - Tool Poisoning	Tampering	TBD	Open		Malicious modifications corrupt tool metadata or functionality.	Provide remediation for this threat or a reason if status is N/A
98	Resource Content Poisoning	Repudiation	TBD	Open		Similar to prompt injection but hidden in data sources the MCP server provides to the LLM. Database records, documents, or API responses contain hidden instructions that activate during processing.	Provide remediation for this threat or a reason if status is N/A
99	Path Traversal	Tampering	TBD	Open		File system access controls bypassed using directory traversal sequences (../, ..\). MCP tools that handle file operations often fail to sanitize paths, allowing access outside intended directories.	Provide remediation for this threat or a reason if status is N/A
100	Privilege Abuse/Overbroad Permissions	Information disclosure	TBD	Open		Tools configured with broader permissions than necessary for their function. A calculator tool with file system access, or a weather tool with database permissions. Common due to lazy configuration.	Provide remediation for this threat or a reason if status is N/A
104	SQL Injection	Tampering	TBD	Open		User provided data is directly embedded into SQL statements without using parameterized queries.	Provide remediation for this threat or a reason if status is N/A

Authorization server (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
70	Eavesdropping Access Tokens	Information disclosure	TBD	Open		Tokens intercepted during transmission are reused by attackers.	Provide remediation for this threat or a reason if status is N/A
71	Obtaining Access Tokens from Authorization Server Database	Information disclosure	TBD	Open		Attackers exploit database vulnerabilities to retrieve tokens by gaining access to the database or launching a SQL injection attack.	Provide remediation for this threat or a reason if status is N/A
72	Disclosure of Client Credentials during Transmission	Information disclosure	TBD	Open		Login credentials are intercepted during the client authentication process or during OAuth token requests.	Provide remediation for this threat or a reason if status is N/A
73	Obtaining Client Secret from Authorization Server Database	Information disclosure	TBD	Open		Valid client credentials are extracted from stored data	Provide remediation for this threat or a reason if status is N/A
74	Obtaining Client Secret by Online Guessing	Spoofing	TBD	Open		Attackers attempt to brute-force valid client ID/secret pairs	Provide remediation for this threat or a reason if status is N/A